

ZAP Scanning Report

Sites: <http://10.42.3.73:8001> <http://10.42.3.73> <https://etatcivil.sec.gouv.sn>
<http://etatcivil.sec.gouv.sn>

Generated on mar., 16 avr. 2024 16:03:13

ZAP Version: 2.14.0

Summary of Alerts

Niveau de risque	Number of Alerts
Haut	0
Moyen	3

Alertes

Nom	Niveau de risque	Number of Instances
Content Security Policy (CSP) Header Not Set	Moyen	27
Hidden File Found	Moyen	1
Missing Anti-clickjacking Header	Moyen	9

Alert Detail

Moyen	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://10.42.3.73/
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73/%5C%22phpstorm:%5C/%5C/open?file=%5C/var%5C/www%5C/html%5C/pgi%5C/routes%5C/web.php&line=62%5C%22
Méthode	GET
Attaquer	
Evidence	
Other Info	
	http://10.42.3.73/%5C%22phpstorm:%5C/%5C/open?file=%5C/var%5C/www%5C/html%5C

URL	/pgi%5C/vendor%5C/laravel%5C/fortify%5C/src%5C/Http%5C/Controllers%5C/AuthenticatedSessionController.php&line=47%5C%22
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73/%5C%22phpstorm:%5C/%5C/open?file=%5C/var%5C/www%5C/html%5C/pgi%5C/vendor%5C/laravel%5C/fortify%5C/src%5C/Http%5C/Controllers%5C/PasswordResetLinkController.php&line=23%5C%22
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73/forgot-password
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73/login
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73/sitemap.xml
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73:8001/
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73:8001/%5C%22phpstorm:%5C/%5C/open?file=%5C/var%5C/www%5C/html%5C/pf2e%5C/app%5C/Http%5C/Controllers%5C/FrontController.php&line=14%5C%22
Méthode	GET
Attaquer	
Evidence	

Other Info	
URL	http://10.42.3.73:8001/%5C%22phpstorm:%5C/%5C/open?file=%5C/var%5C/www%5C/html%5C/pf2e%5C/vendor%5C/laravel%5C/fortify%5C/src%5C/Http%5C/Controllers%5C/AuthenticatedSessionController.php&line=47%5C%22
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73:8001/buttons/61
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73:8001/entreprise/%5C%22phpstorm:%5C/%5C/open?file=%5C/var%5C/www%5C/html%5C/pf2e%5C/app%5C/Http%5C/Controllers%5C/FrontController.php&line=19%5C%22
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73:8001/entreprise/signup
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73:8001/forgot-password
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73:8001/login
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73:8001/sitemap.xml
Méthode	GET
Attaquer	

Evidence	
Other Info	
URL	http://etatcivil.sec.gouv.sn
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	https://etatcivil.sec.gouv.sn/
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	https://etatcivil.sec.gouv.sn/_darcs
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	https://etatcivil.sec.gouv.sn/.bzr
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	https://etatcivil.sec.gouv.sn/hg
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	https://etatcivil.sec.gouv.sn/BitKeeper
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	https://etatcivil.sec.gouv.sn/latest
Méthode	GET
Attaquer	
Evidence	
Other	

Info	
URL	https://etatcivil.sec.gouv.sn/latest/meta-data
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	https://etatcivil.sec.gouv.sn/latest/meta-data/
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	https://etatcivil.sec.gouv.sn/robots.txt
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	https://etatcivil.sec.gouv.sn/sitemap.xml
Méthode	GET
Attaquer	
Evidence	
Other Info	
Instances	27
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/CSP/Introducing_Content_Security_Policy https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html http://www.w3.org/TR/CSP/ http://w3c.github.io/webappsec/specs/content-security-policy/csp-specification.dev.html http://www.html5rocks.com/en/tutorials/security/content-security-policy/ http://caniuse.com/#feat=contentsecuritypolicy http://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Moyen	Hidden File Found
Description	A sensitive file was identified as accessible or available. This may leak administrative, configuration, or credential information which can be leveraged by a malicious individual to further attack the system or conduct social engineering efforts.
URL	http://10.42.3.73/.DS_Store
Méthode	GET
Attaquer	

Evidence	HTTP/1.1 200 OK
Other Info	ds_store
Instances	1
Solution	Consider whether or not the component is actually required in production, if it isn't then disable it. If it is then ensure access to it requires appropriate authentication and authorization, or limit exposure to internal systems or specific source IPs, etc.
Reference	https://blog.hboeck.de/archives/892-Introducing-Snallygaster-a-Tool-to-Scan-for-Secrets-on-Web-Servers.html
CWE Id	538
WASC Id	13
Plugin Id	40035

Moyen	Missing Anti-clickjacking Header
Description	The response does not include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options to protect against 'ClickJacking' attacks.
URL	http://10.42.3.73/
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73/forgot-password
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73/login
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73:8001/
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73:8001/entreprise/signup
Méthode	GET
Attaquer	
Evidence	
Other Info	

URL	http://10.42.3.73:8001/forgot-password
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://10.42.3.73:8001/login
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	http://etatcivil.sec.gouv.sn
Méthode	GET
Attaquer	
Evidence	
Other Info	
URL	https://etatcivil.sec.gouv.sn/
Méthode	GET
Attaquer	
Evidence	
Other Info	
Instances	9
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020